Threat Research Report: APT29 Targeted Spearphishing Campaign

Classification: Amber | Actor: APT29 / Midnight Blizzard | Vector: Deceptive Diplomatic Lures

Campaign Overview

State-sponsored cyber espionage group APT29 conducted coordinated spearphishing campaigns targeting defense and governmental contractors. Attackers distributed weaponized container files (.iso and .vhd) masquerading as summit invitation schedules.

Interception Evidence from Mail Gateway: Sender: diplomatic-summit@foreign-affairs-press[.]example[.]org Recipient: defense-contracts@enterprise.example.com Subject: URGENT: Bilateral Security Council Delegate Pass & Credentials Verification Link: hxxps://sso-secure-portal[.]example[.]com/auth/summit_login.php Embedded Attachment: delegate_credentials_package.iso

Once mounted by the victim, an embedded LNK shortcut initiates Windows Rundll32 to load a hidden DLL payload. The implant establishes encrypted reverse HTTPS tunnels to C2 server 203.0.113.88 and executes Mimikatz in memory to dump local LSASS credentials and Kerberos tickets.

Observed Threat Indicators

Indicator Value	Type	Threat Context	Status
foreign-affairs-press[.]example[.]org	Domain	Spoofed Diplomatic Sender	Malicious
hxxps://sso-secure-portal[.]example[.]com/auth/summit_login.php	URL	Credential Harvesting Endpoint	Malicious
sso-secure-portal[.]example[.]com	Domain	Phishing Infrastructure	Malicious
203.0.113.88	IPv4	APT29 C2 Listener Node	Malicious
8743b52063cd84097a65d1633f5c74f5	MD5	Weaponized LNK Loader	Malicious
cve-2023-38831	CVE	WinRAR Code Execution Vector	High Risk

Tactics, Techniques, and Procedures (TTPs)

- **T1566.001 (Spearphishing Attachment)**: Delivery of malicious ISO containers via email.
- **T1204.002 (Malicious File Execution)**: Relying on victim to click the disguised LNK document.
- **T1003.001 (OS Credential Dumping)**: Execution of Mimikatz memory injection against lsass.exe.
- **T1071.001 (Web Protocols C2)**: Covert telemetry exchange over port 443.

Defensive Mitigations & Threat Hunting Queries

1. **File Block Rule**: Block incoming emails containing ISO, VHD, or LNK file attachments at the perimeter secure email gateway.

2. **Sigma Rule Execution**: Search for rundll32.exe executions spawning cmd.exe or powershell.exe with network connections.

3. **Credential Invalidation**: Invalidate cached Kerberos tickets and enforce Credential Guard across Windows 11 endpoints.

Triage Assessment: HIGH SEVERITY (Score: 8.9 / 10.0)